INCIDENT INVESTIGATION REPORT

SOC | FORENSIC

Title: Forensic Analysis and Detection of Lateral Movement and Malware Installation in a DMZ Environment
Author: Esteban Espitia
Role: SOC Analyst Tier 1 / Threat Hunter
Analysis Date: August 2024
Monitoring Platform: Wazuh SIEM / OpenSearch Dashboards
Event Timeframe: 08/01/2024 00:00 - 08/07/2024 00:00 UTC

1. EXECUTIVE SUMMARY

During the evaluated period, malicious activity divided into multiple phases was identified and analyzed across the demilitarized zone (DMZ) infrastructure. A threat actor successfully modified perimetric firewall rules to gain SSH access to an exposed web server (172.16.8.190). Following the initial intrusion, the attacker escalated privileges to root, installed the nmap scanning tool via the yum package manager, and performed internal reconnaissance (Port Scanning) on the 10.10.10.0/24 network segment. After executing an SSH brute-force attack against internal network assets, they successfully compromised database server db4 (10.10.10.24).

2. METADATA AND AFFECTED ENVIRONMENTS

Environment / Asset	IP Address	Function	Operating System / Service
Perimetric Firewall	192.168.5.8 (GUI Admin)	FortiGate Firewall	FortiOS
Webserver (DMZ)	172.16.8.190	Compromised Web Server	Linux (Rocky / RHEL)
Internal Subnet	10.10.10.0/24	Internal Server Network	Linux
DB Server 4 (Target)	10.10.10.24	Database Server	Linux (Rocky / RHEL)

3. INCIDENT TIMELINE

- [08/01/2024 07:09:54 UTC] → Modification of perimetric firewall rule (Allows SSH to 172.16.8.190)
- [08/02/2024 16:17:54 UTC] → Massive SSH brute-force attack toward the internal network (24 burst attempts)
- [08/02/2024 18:08:53 UTC] → Unauthorized installation of the Nmap package via Yum on Webserver
- [08/02/2024 18:10:13 UTC] → Execution of Nmap SYN scan on subnet 10.10.10.0/24 targeting port 22
- [08/02/2024 21:17:54 UTC] → Logging of 8 failed SSH attempts from 172.16.8.190 toward internal targets
- [08/02/2024 21:17:55 UTC] → Successful SSH authentication to the root account on server db4 (10.10.10.24)

4. DETAILED FORENSIC ANALYSIS BY PHASE

Phase 1: Initial Access and Firewall Modification

- **Finding:** The creation of a FortiGate firewall policy identified with logid: 13579 was detected. The modification allowed incoming traffic on port 22 (SSH) to the web server (172.16.8.190).
- **User Involved:** fwadmin via the GUI interface (192.168.5.8).
- **Filters used in Wazuh:** rule.groups: firewall AND data.subtype: system.
- **Evidence (Log Snippet):**
  JSON
  ```
  "data": {
    "dstuser": "fwadmin",
    "logid": "13579",
    "action": "Add",
    "cfgpath": "firewall.service.custom",
    "cfgattr": "action[accept] srcaddr[all] dstaddr[172.16.8.190] service [ssh] nat[enable]"
  }
  ```

Phase 2: Attack Tools Installation (Post-Exploitation)

- **Finding:** After gaining access to server 172.16.8.190, the attacker used the yum package manager to install reconnaissance utilities.
- **Installed Application:** nmap-6.40-19.el7.x86_64.
- **Filters used in Wazuh:** agent.name: webserver AND rule.groups: yum.
- **Evidence (Log Snippet):**
  Plaintext
  ```
  full_log: "Aug 02 18:08:53 webserver yum [8357]: Installed: nmap-6.40-19.el7.x86_64"
  ```

Phase 3: Internal Reconnaissance (Network Scanning)

- **Finding:** Through the auditd subsystem, system calls (syscall 59: execve) executed with root privileges (uid: 0) were captured. The attacker scanned the internal subnet searching for active SSH servers.
- **Executed Command:** /usr/bin/nmap -sS -Pn -n -p 22 10.10.10.0/24
- **Analyzed Parameters:**
  - -sS: SYN Scan (Stealth scan).
  - -p 22: Target port (SSH).
  - 10.10.10.0/24: Target network block.
- **Evidence (Log Snippet - auditd):**
  JSON
  ```
  "execve": {
    "a0": "nmap",
    "a1": "-sS",
    "a2": "-Pn",
    "a3": "-n",
    "a4": "-p",
    "a5": "22",
    "a6": "10.10.10.0/24"
  }
  ```

Phase 4: Lateral Movement and Asset Compromise (Credential Access)

- **Finding:** Server 172.16.8.190 was used as a pivot to launch brute-force attacks against the internal network. A total of 8 failed authentication attempts were recorded before successfully compromising a target.
- **Attack Result:** Successful authentication on database server db4 (10.10.10.24) as user root.
- **Filters used in Wazuh:** data.srcip: 172.16.8.190, rule.groups: sshd, rule.groups: authentication_success.
- **Evidence (Log Snippet):**
  Plaintext
  full_log: "Aug 2 21:17:55 db4 sshd[8286]: Accepted password for root from 172.16.8.190 port 51511 ssh2"[cite: 8, 9, 10]

5. MITRE ATT&CK MAPPING

Tactic	Tech ID	Technique Name	Incident Description
Initial Access	T1190	Exploit Public-Facing Application	Exposure of SSH on web server following firewall change.
Execution	T1059.004	Unix Shell	Execution of commands in Linux console via auditd.
Persistence / Priv Esc	T1078	Valid Accounts	Illegitimate use of root credentials via SSH on 10.10.10.24.
Discovery	T1046	Network Service Discovery	Port scanning with nmap targeting subnet 10.10.10.0/24.
Lateral Movement	T1021.004	Remote Services: SSH	Pivoting from 172.16.8.190 to 10.10.10.24.

6. MITIGATION AND REMEDIATION RECOMMENDATIONS

- **1. Segmentation and Access Control:**
  - Revoke firewall rule logid: 13579. The web server's SSH port must not be directly exposed to the Internet.
  - Implement a Bastion Host / VPN solution with Multi-Factor Authentication (MFA) for administrative access.
- **2. SSH Hardening:**
  - Disable direct access to the root account via SSH on all Linux servers (PermitRootLogin no in /etc/ssh/sshd_config).
  - Implement authentication based solely on cryptographic keys (disable PasswordAuthentication).
- **3. Software Restriction:**
  - Restrict the use of package managers (yum/dnf) on production servers exclusively to authorized maintenance windows.

- Configure rules in Wazuh to immediately alert on installations of security evaluation binaries (nmap, masscan, nc).